

Table of Contents

CSW compliance evidence playbook

Audience: Security engineers, GRC analysts, and Cisco SEs who are **new to Cisco Secure Workload (CSW)** and need a repeatable way to turn CSW deployment into **assessor-ready evidence** for any framework in this repository.

Companion to [About CSW](#) and the per-framework **Reference Designs** (*-Reference-Design.md).

What this playbook is (and is not)

This playbook is	This playbook is not
Step-by-step CSW operations for evidence collection	Legal or audit sign-off
A cadence you can run quarterly	A substitute for your QSA, OCR, or C3PAO
Framework-agnostic CSW mechanics	The full control text of HIPAA, PCI, etc.

Every framework reference design maps **specific control IDs** to CSW artefacts. **Start here** for *how*; open the framework reference design for *which controls*.

CSW in five minutes (new operators)

CSW protects **workloads** (servers, VMs, containers) — not the network perimeter alone.

Agent on workload → observes processes + flows → CSW SaaS console
↓
Scopes + labels (compliance boundary)
↓
ADM (learn who talks to whom)
↓
Policy workspace (allow / deny / log)
↓
Monitor → Simulation → Enforce
↓
Exports = audit evidence

Console map

Area	Menu path (typical)	Use for evidence
Inventory	Investigate → Inventory / Workloads	Scope membership, agent health
Flows	Investigate → Flows / Flow Search	Who talked to whom, when, on which port
Processes	Investigate → Processes	Which binary opened the connection
ADM	Policy Lifecycle → ADM / Dependency map	Live application diagram
Policy	Defend → Segmentation / Workspaces	Allow/deny rules, simulation, enforce
Denied traffic	Defend → Denied Connections	Proof enforcement blocked a flow
Vulnerabilities	Investigate → Vulnerability	CVE + workload + reachability context
Agents	Manage → Agents / Sensors	Coverage %, enforcement mode
Connectors	Platform → Orchestrators	Cloud inventory without agents
Audit	Administration → Audit logs	Who changed policy in CSW

Modes (always in this order for compliance rollouts)

Mode	Traffic impact	Evidence value
Visibility / Monitor	None — observe only	Baseline flows, ADM, scope proof
Simulation	None — predict blocks	Safe pre-enforcement report for change board
Enforcement	Blocks non-matching traffic	Primary segmentation control evidence

Never skip Simulation before Enforce in regulated environments.

The universal 4-phase evidence programme

Run this once per compliance boundary (CDE, PHI zone, CUI enclave, SWIFT zone, etc.). Timelines assume a pilot scope of 20–200 workloads; scale phases proportionally.

Phase 1 — Coverage and inventory (Days 1–10)

Goal: Prove every in-scope system component appears in CSW and is labeled.

Step	Action	CSW location	Evidence artefact
1.1	Define in-scope IP/host list from compliance scope doc	(customer doc)	Scope document (input)
1.2	Install agents or enable cloud connectors	Manage → Agents; Platform → Connectors	Agent inventory export
1.3	Verify 100% of scope list appears in inventory	Investigate → Inventory (filter by label/subnet)	Screenshot + CSV export
1.4	Apply labels: compliance:<framework>, data:<class>, env:<tier>	Inventory → Labels	Label policy doc
1.5	Create CSW scope matching compliance boundary	Scopes / App scopes	Scope definition export

Pass criteria: No in-scope workload missing from inventory for >24 h without documented exception.

CSW effectiveness: Replaces manual CMDB reconciliation samples with **continuous** inventory tied to observed behaviour.

Phase 2 — Behaviour baseline (Days 11–28)

Goal: Produce a **machine-generated** communication map assessors treat as stronger than static diagrams.

Step	Action	CSW location	Evidence artefact
2.1	Start ADM on compliance scope; run ≥2 weeks (include billing/month-end if applicable)	ADM / Application Dependency Mapping	ADM cluster report
2.2	Document unexpected flows	Investigate → Flow Search	Anomaly flow export

Step	Action	CSW location	Evidence artefact
	(scope creep, shadow IT, vendor egress)		
2.3	Capture process context on critical flows (DB, auth, integration)	Flow detail → process column	Flow+process screenshot
2.4	Map ADM clusters to application owners; confirm data classification	(workshop)	Signed app-to-cluster table
2.5	Export dependency map for assessor	ADM → Export / screenshot	Live network diagram artefact

Pass criteria: App owners attest ADM matches expected architecture; exceptions documented.

CSW effectiveness: PCI Req 1.2.1, HIPAA risk analysis, and NIST CM-2 all ask for **current** connectivity — ADM answers from telemetry, not last year's Visio.

Phase 3 — Policy and simulation (Days 29–45)

Goal: Show **designed** isolation before you **enforce** it.

Step	Action	CSW location	Evidence artefact
3.1	Create policy workspace bound to compliance scope	Defend → Segmentation	Workspace config
3.2	Import ADM-suggested rules; add explicit DENY defaults	Policy editor	Policy export (JSON/CSV)
3.3	Run Simulation for 1–2 weeks	Workspace → Simulation mode	Simulation hit report
3.4	Remediate false positives with app owners	(change tickets)	Change log
3.5	Document compensating controls for rules	(GRC register)	Exception register

Step	Action	CSW location	Evidence artefact
	deferred		

Pass criteria: Simulation shows no business-breaking denies; all unmatched flows either allowed by rule or logged.

CSW effectiveness: Simulation produces **change-board-ready** evidence — critical for HIPAA, PCI, and FedRAMP change control (CM-3, Req 6.4).

Phase 4 — Enforcement and continuous proof (Day 46+)

Goal: Demonstrate controls **operate effectively** between audit cycles (PCI v4.0 language).

Step	Action	CSW location	Evidence artefact
4.1	Enable Enforcement on lowest-risk scope first	Workspace → Enforce	Enforcement screenshot
4.2	Run controlled negative test (unauthorized flow should fail)	ping/curl + Denied Connections	Test record + deny log
4.3	Export quarterly evidence pack (see table below)	Multiple	Audit binder
4.4	Integrate CSW alerts to SIEM (Splunk, Sentinel, etc.)	Platform → Integrations	SIEM sample events
4.5	Re-run ADM every 90 days; compare to policy baseline	ADM diff	Drift report

Pass criteria: Denied Connections shows test violation; production apps stable; quarterly pack complete.

CSW effectiveness: Moves from **point-in-time** audit samples (SOC 2 CC6) to **continuous** workload-resident proof.

Quarterly evidence pack (copy into every framework)

Export these every quarter (or per your assessor's cadence). Map columns to control IDs using your framework reference design Section 10+.

#	Artefact	CSW source	Typical controls
1	Scope membership snapshot	Inventory → Export (filtered by compliance scope)	Scope / asset inventory
2	Agent coverage report	Manage → Agents (% active, enforce mode)	Monitoring / logging
3	Policy workspace export	Defend → Export policies	Access control / segmentation
4	Denied Connections log (90 days)	Defend → Denied Connections	Enforcement proof
5	ADM / dependency map	ADM export	Network diagram / data flows
6	Vulnerability report (scoped)	Investigate → Vulnerability	Risk analysis / patch priority
7	Policy change / audit log	Administration → Audit	Change management
8	Sample incident flow export	Investigate → Flow Search (if incident occurred)	Incident response
9	Simulation or enforcement attestation	Workspace status + sign-off	Operating effectiveness
10	Exception / break-glass register	(customer GRC)	Compensating controls

Store exports in your GRC tool with: **date, scope, CSW tenant URL, exporting user, framework version.**

API and automation (optional)

For repeatable evidence collection, use CSW OpenAPI (HMAC auth):

```
# Example: agent inventory
```

```
python3 csw_api.py GET /openapi/v1/sensors
```

```
# Example: inventory search by label
```

```
python3 csw_api.py POST /openapi/v1/inventory/search \
```

```
'{"filter":  
{"type":"eq","field":"labels","value":"compliance:hipaa"},"dimensions"  
:["ip","hostname","enforcement_status"],"limit":500}'
```

See [CSW-POV-Tooling](#) or Cursor skill `csw-api` for helper scripts. **Never commit API keys** to this repository.

Pairing with the customer-facing report

Document	Role
This playbook + framework reference design	Engineers execute phases; GRC maps exports to control IDs
Compliance Report (PDF/DOCX)	Customer/auditor narrative; posture summary table
Framework Scope Design Guide	Workshop: which scopes/labels before Phase 1

Workflow: **Reference design** → **populate real exports** → **tailor Report placeholders** → **assessor review**.

CSW effectiveness — why programmes choose it

Compliance pain	Traditional approach	CSW approach
"Prove segmentation"	Annual firewall rule review + static diagram	Continuous enforce + Denied Connections
"Prove scope"	Spreadsheet vs. CMDB	Live inventory + labels + scope queries
"Prove logging"	SIEM only (may miss east-west)	Workload flow + process telemetry
"Prove vuln priority"	CVE list without reachability	CVE on workload + who can connect
"Prove lateral movement control"	Assume VLANs work	East-west policy at process/workload tier
"Prove change control"	Sample of change tickets	Policy audit log + ADM drift vs. baseline

CSW does **not** replace governance, physical security, encryption key management, or formal penetration testing — it **compresses** the workload-resident slice of evidence into one queryable system.

Next steps

1. Pick your framework folder → open *-Reference-Design.md.
2. Read **Reader's Guide** + **CSW primer** (injected section) for your industry.
3. Execute Phases 1–4 above; use framework Section 10 for control ID mapping.
4. Tailor the matching **Compliance Report** for leadership/auditor conversations.
5. Validate with your assessor before formal reliance — see [repository disclaimer](#).